

-

File No: EXP202303134

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 31, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against PRESTAMER, S.L. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No: EXP202303134

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on January 31, 2023. The complaint is directed against PRESTAMER, S.L. with NIF B54947403. The reasons for the complaint are as follows:

The complainant claims to have received an email from PRESTAMER, S.L., dated 31/1/23, sent to dozens of recipients, specifying a total of 472 recipients, without using the blind carbon copy (BCC) functionality, so that the addresses of the recipients, many of which consist of the names and surnames of the affected individuals, are visible to all of them. A copy of the email sent by PRESTAMER, S.L. is attached to the notification.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to PRESTAMER, S.L. for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/11

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on March 13, 2023, as evidenced by the acknowledgment of receipt in the file.

On April 11, 2023, the respondent responded to the forwarding and request for information, and a written response was received in this Agency in which PRESTAMER, S.L. considers that the facts that led to the complaint stem from a punctual error and without intent. It states that in the email sent, 477 email addresses can be identified, considering that "it does not individually identify each natural person, since a natural person may have provided several email addresses" and that, on the other hand, the category of data communicated without authorization is contact data, so the impact on privacy is very limited.

THIRD: On April 20, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

The complainant is a client of the entity who has previously been informed of the existence of a debt. On January 31, 2023, an email was sent from the address ***EMAIL.1@PRESTAMER.ES to multiple email addresses referring to the debtor situation. This email is a reminder to indicate an alternative

dispute resolution mechanism for debt recovery and is sent to those clients who are in the same situation. The number of email addresses included corresponds to 477.

The entity has, among others, a document titled Functions and Obligations of Staff with Access to Data, dated October 3, 2022, which is provided to all employees and signed by them, specifying the obligations regarding data protection. They also have a document Basic Rules for Data Security, which states, "Do not send sensitive information by email without additional security measures.

Communications should not be sent to recipients outside the organization in visible copy, but the blind copy (BCC) format should be used."

An employee of the entity, by mistake, does not realize that they have entered the recipients' data in the copy (CC) field, which allows the email addresses of the recipients to be visible. The employee does not notice at any time that unauthorized communication has occurred, so they do not report the security breach.

The company has defined a Data Processing Protocol by the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/11

teleoperators, suspending the sending of mass emails until an automated email sending tool is implemented.

The entity provides the result of the assessment of the COMUNICABRECHA tool, which indicates "SHOULD NOTIFY THE AFFECTED PARTIES OF THE SECURITY BREACH" and states that it is not necessary to notify the AEPD since it was the Agency itself that notified the incident to the company.

FIFTH: According to the report collected from the AXESOR tool, the entity PRESTAMER, S.L. is an SME with 5 employees, a subsidiary of the AS ROBOCASH GROUP, whose activity corresponds to "Other credit activities." The sales volume is 5,257,077 euros in the 2022 financial year.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of the GDPR and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, according to the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, as PRESTAMER, S.L. uses personal data in its business activity.

PRESTAMER, S.L. carries out this activity in its capacity as data controller, as it determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" as "all breaches of security that result in the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed." In this case, there is a personal data security breach under the circumstances indicated above, categorized as a confidentiality breach, resulting from the sending of an email without blind carbon copy (BCC), making the email addresses of the recipients accessible, many of which consist of the names and surnames of the affected individuals and are visible to all of them.

III

Unfulfilled Obligation

The known facts could constitute an infringement attributable to PRESTAMER, S.L., as outlined in Article 5.1.f) of the GDPR and Article 32 of the GDPR.

First, Article 5 of the GDPR establishes the principles that must govern the processing of personal data, and second, Article 32 of the GDPR regulates the security of processing.

IV.

Article 5.1.f)

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In accordance with the evidence available at this moment regarding the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that

PRESTAMER, S.L. has processed personal data of the complainant and the other holders of those email addresses by sending emails to multiple people without using the BCC function, violating the confidentiality in the processing of personal data, without adopting the technical and organizational measures of all kinds required by the regulations on personal data protection, and therefore this fact could constitute an infringement for violation of Article 5.1.f) of the GDPR.

V

Classification and Qualification of the Infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading

"General conditions for the imposition of administrative fines" provides:

"Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual worldwide turnover."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/11

total annual global business of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data promptly in the event of a physical

or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

In accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered that, in this case, PRESTAMER, S.L did not have appropriate technical and organizational security measures in relation to the use of personal email accounts based on the estimated potential risks and, therefore, the known facts could constitute an infringement for violation of Article 32 of the GDPR. Security measures that are deemed inappropriate, even if no personal data of the complainant had been communicated to a third party. Subsequently, the controller proceeded to analyze the security breach, adopting initial measures aimed at mitigating its impact and reducing the risk of future threats materializing. New measures have been implemented to prevent the recurrence of such errors in the future. The incident has also been communicated to all affected parties.

VII

Classification and qualification of the infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/11

"Based on the provisions of Article 83.4 of Regulation (EU) 2016/679, serious infringements that constitute a substantial violation of the articles mentioned therein shall be subject to a two-year limitation period, particularly the following:

f) The failure to adopt appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679." (...)

VIII

Sanction for the infringement of Article 5.1.f) and 32 of the GDPR

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. Therefore, it is necessary to assess the sanction to be imposed in accordance with the criteria established in Article 83.2 of the GDPR, and

with the provisions of Article 76 of the LOPDGDD.

Article 83.2 of the GDPR states that:

"2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j).

When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity and circumstances of the infringement,

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

In this case, without prejudice to the outcome of the investigation, for the purpose of determining the amount of the sanction for the infringement of Article 5.1 f), it is appropriate to assess the fine taking into account as aggravating factors both the nature of the data and the number of affected individuals as well as the level of damage and harm they may have suffered (83.2 a) as well as the negligence in the commission of the infringement (83.2 b).

On the other hand, and without prejudice to the outcome of the investigation of the procedure, for the purpose of determining the amount of the sanction for the infringement of Article 32 of the GDPR, it is appropriate to assess the fine taking into account as an aggravating factor the link of the infringer's activity with the processing of personal data, according to Article 76.2. b of the LOPDGDD. The activity of the respondent requires continuous processing of personal data and for the development of its activity, it carries out a high volume of personal data processing.

For all these reasons, it is considered that the sanction to be imposed would be 2,000 euros for the infringement of Article 5.1 f) of the GDPR and 1,000 euros for the infringement of Article 32 of the GDPR, totaling 3,000 euros.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/11

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against PRESTAMER, S.L., with NIF B54947403, for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified, respectively, in Articles 83.5 and 83.4 of the GDPR.

SECOND: TO APPOINT R.R.R. as the instructor and S.S.S. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the complainant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided for in Article 64.2 b) of the LPACAP, the sanction that may correspond would be, without prejudice to the outcome of the investigation;

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of that regulation, an administrative fine of 2,000.00 euros.

- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of that regulation, an administrative fine of 1,000.00 euros.

This totals an amount of 3,000 € (THREE THOUSAND EUROS).

FIFTH: TO NOTIFY this agreement to PRESTAMER, S.L., with NIF B54947403, granting a hearing period of ten working days for it to submit any allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number indicated in the heading of this document.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of the LPACAP.

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; which will entail a reduction of 20% of the sanction to be imposed in this procedure. With the application of this reduction, the sanction would be set at 2,400.00 euros, resolving the procedure with the imposition of this sanction.

Likewise, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 2,400.00 euros and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/11

The reduction for the voluntary payment of the sanction is cumulative with the one that corresponds to be applied for the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be established at 1,800.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

In the event that you choose to proceed with the voluntary payment of any of the amounts indicated above (2,400.00 euros or 1,800.00 euros), you must make it effective by depositing it into account no. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of deposit to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-290523

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On February 7, 2024, the respondent has proceeded to pay the sanction in the amount of 1,800 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the renunciation of any action or appeal in the administrative route against the sanction and the acknowledgment of responsibility concerning the facts referred to in the Initiation

Agreement.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides the following:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the imposition of the latter has been justified as inappropriate, the voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which will be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/11

The percentage of reduction provided for in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202303134, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to PRESTAMER, S.L.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as stipulated by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

936-040822

Mar España Martí

Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es